INFORME EJECUTIVO DE CIBERSEGURIDAD

Proyecto: Auditoría Google Gruyere

Fecha: Junio 2026

1. RESUMEN EJECUTIVO

Este informe detalla los hallazgos de la auditoría técnica realizada sobre la aplicación Google Gruyere. El objetivo ha sido identificar vulnerabilidades que comprometan la confidencialidad, integridad y disponibilidad del sistema.

Tras un análisis exhaustivo, se ha dictaminado un Nivel de Riesgo Global: ALTO. La aplicación presenta fallos críticos en la gestión de entradas de usuario, exposición de código fuente y falta de mecanismos de protección básicos, lo que permitiría a un atacante comprometer la plataforma con facilidad.

2. ALCANCE Y METODOLOGÍA

La evaluación se dividió en fases secuenciales:
* Footprinting (Pasivo): Recopilación de información pública (DNS, WHOIS, OSINT).
* Fingerprinting (Activo): Escaneo de servicios, puertos y tecnologías (Nmap, WhatWeb).
* Análisis de Vulnerabilidades: Pruebas de inyección y configuraciones de seguridad (ZAP, Wapiti).

3. HALLAZGOS PRINCIPALES

• Exposición de Código Fuente (Criticidad: Crítica): Revelación de lógica de negocio, archivos sensibles y credenciales.
• Inyección SQL (Criticidad: Alta): Compromiso total de la base de datos mediante consultas no parametrizadas.
• Cross-Site Scripting (XSS) (Criticidad: Alta): Robo de sesiones y ataques dirigidos a usuarios finales mediante código persistente.
• Clickjacking (Criticidad: Media): Posibilidad de engañar a usuarios legítimos para realizar acciones inadvertidas.

4. ANÁLISIS TÉCNICO

4.1. Exposición de Código: Se ha detectado acceso público al directorio /code/, exponiendo archivos críticos y lógica de backend.

4.2. Fallos de Backend: La falta de sanitización en el backend permite inyecciones SQL y ataques XSS persistentes. El sistema confía excesivamente en los datos proporcionados por el cliente.

5. CONCLUSIONES Y PLAN DE ACCIÓN

1. Acceso: Restringir inmediatamente el acceso público al directorio de código fuente.
2. Desarrollo Seguro: Implementar consultas parametrizadas y sanitización estricta de todas las entradas del usuario.
3. Seguridad Web: Configurar cabeceras HTTP de seguridad (X-Frame-Options) y forzar el uso de HTTPS.
4. Control: Añadir mecanismos de verificación (CAPTCHA) en los formularios de registro.